

The Psychology of Social Engineering

Why Attackers Attack People

Humans:

- Are busy and distracted
- Want to help / be polite
- Fear authority and urgency
- Follow process blindly
- Are easier than software to exploit

Social engineering bypasses every firewall, AV, and EDR on the planet, because the "compromise" happens in a human brain.

The Six Influence Principles (Cialdini)

- Authority** – "IT Support calling, I need your password NOW"
- Scarcity** – "Only 3 licenses left, act today!"
- Urgency** – "Your account will be locked in 24h unless you verify"
- Reciprocity** – "Here's a free gift; just confirm your details"
- Consistency/Commitment** – "You already signed up; just update the details"
- Social proof** – "Thousands already updated, you should too"

The attacker's job is to trigger these levers faster than you can think. Your defense is a pause: *Who is actually asking? Why would they ask THIS way?*

The Helper's Dilemma

Legitimate help desks ask for details. Attackers mimic that. The tension: a good culture is trusting; a secure culture questions. Solutions:

- Verify in a different channel – hang up and call the known number
- Never give *current* secrets – passwords, MFA codes, OTPs are never "re-confirmed" by real IT
- The password reset rule – real support resets, never asks for the existing one

The "Human Firewall" Model

Treat *employees as sensors*, not as the weakest link:

- Training: recognize + report (phishing drills)
- Reporting: one-click "report phishing" that reaches SOC
- Rewards: praise reports, never punish a "was tricked" employee (they report NEXT time)
- Process: no executive override by email/phone alone (the classic "CEO fraud")

Pretexting, Baiting & Tailgating

Technique	Play
Pretexting	Attacker fabricates a <i>story</i> (the pretext) to get info ("I'm from compliance, need your inventory")
Baiting	Physical/digital treats: infected USB ("Free movies!")
Tailgating/piggybacking	Follow someone through a badge door
Quid pro quo	"I'll fix your printer for your password"
Dumpster diving	Physical recovery of sensitive documents

Blue-team insight: treat every "unexpected request for information or action" as the trigger to verify. That one behavior blocks most of the playbook.

[← Module start](#)

[Phishing: Anatomy & Detection →](#)